

Festo Smart Factory Lab - Final Assignment

Aleksander Klap & Lourdes Gaurisse

June 22, 2026

Contents

List of Tables

List of Figures

1 Introduction & Scope

This report assesses and redesigns the cybersecurity posture of the Fontys Festo Smart Factory Lab 4.0. The factory is functionally operational but was not designed against state-of-the-art OT security principles.

The work follows four phases: describe the current (AS-IS) state, perform a threat and risk analysis, specify security requirements, and design a secure-by-design (TO-BE) architecture including supporting hardware recommendation and procedures to follow. The goal is to protect availability, integrity, and confidentiality while keeping the lab operational.

Scope. The project covers the OT/ICS network of the lab with the six manufacturing stations. The work is to understand and analyse the factory as it currently runs, assess the security risks, and design a new architecture that is secure and meets the required security measures.

Standards. The redesign is based on the standards and principles required by the assignment:

- IEC 62443
- ISO/IEC 27001
- NIS2 Directive
- Defense-in-Depth principle,
- Least Privilege & Zero Trust (industrial interpretation)

2 Festo Factory Description

The Festo CPLab is a modular production line representing a modern Industry 4.0 plant. It consists of seven cells:

- Station 0 — Robot Arm: Universal Robots UR3e pick-and-place cobot with a Turck RFID reader.
- Station 1 — Conveyor Belt: transport between stations.
- Station 2 — Ball Sorting / Dispense: sorting and dispensing, with remote I/O and a power monitor.
- Station 3 — Camera Inspection: SensoPart vision sensor for quality inspection.
- Station 4 — Magazine: part storage and a Festo CPX cloud-connected valve/IO terminal.
- Station 5 — Muscle Press: pneumatic press.
- Station 6 — Oven: curing/heating, with a Festo CPX controller and power monitor.

The line runs as an order-driven manufacturing process. A production order enters through the MES, which is linked to a webshop, and the MES schedules the job and releases it to the line. Each workpiece is identified by RFID and tracked as it moves between stations on the conveyor. The robot arm handles pick-and-place, and the workpiece passes through the stations for sorting and dispensing, pressing, oven curing, and camera inspection before storage in the magazine. Station status and results are reported back to the MES, which tracks each order through to completion. The hardware, network, and protocols behind this flow are detailed in the following sections.

3 AS-IS Architecture

This section documents the Festo Plant factory in its current operational setup.

3.1 Asset Inventory

Network Infrastructure

Asset	Model	IP	MAC	Protocols	Function
MES PC	SIMATIC-PC	172.21.0.90	4c:d7:17:90:73:a2	OPC UA, NTP, HTTP, HTTPS	MES, MES database, NTP server
MQTT device	Festo	172.21.0.210	00:0E:F0:7C:A3:C0	MQTT	MQTT device publishing telemetry data to MES
Router	TP-Link router	172.21.0.200	20:23:51:41:a2:88	UDP	Router

Station 0 — Robot Arm Station (172.21.1.x/18)

Asset	Model	IP	MAC	Protocols	Function
Switch S0	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 0 network distribution
PLC - TODO					
HMI - TODO					
Robot Arm Controller	UR3e	TODO ip	TODO mac	UR Bus / Ethernet	Pick & place robot arm control
RFID Reader	Turck TBEN-S2-2RFID-4DXP	172.21.1.20	00:07:46:aa:07:cc	PROFINET	RFID identification of transport trays

Station 1 — Conveyor Belt (172.21.1.x)

Asset	Model	IP	MAC	Protocols	Function
Switch S1	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 1 distribution
HMI S1	Siemens MTP700 Unified Comfort	172.21.1.10	30:13:89:35:da:a8	PROFINET	Operator panel (confirm ownership)
PLC S1	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.1.1	30:B8:51:32:D3:E7	PROFINET, HTTP, OPC-UA, S7comm	Process control S1
PC Cobot-ML	unknown	172.21.1.90	08:bf:b8:f1:25:e3	OPC-UA, HTTP	Image Processing

Station 2 — Ball Sorting / Dispense (172.21.2.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S2	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 2 distribution
PLC S2	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.2.1	30:b8:51:33:7e:c7	PROFINET, HTTP, OPC-UA, S7comm	Process control S2
HMI S2	Siemens MTP700 Unified Comfort	172.21.2.10	30:13:89:35:d8:af	PROFINET, S7comm+, NTP	Operator panel
FESTO COntroller - TODO					
Power Monitor S2	Siemens	172.21.2.61	10:DF:FC:17:DC:72	TODO	Power consumption monitoring
IO Device	Siemens ET200SP IM155-6PN/2 HF / V4.2.4	172.21.2.100	4c:e7:05:4b:46:4b	PROFINET IO	Remote IO module - ball dispenser control

Station 3 — Camera Inspection (172.21.3.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S3	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 3 distribution
PLC S3	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.3.1	30:b8:51:32:d3:9b	PROFINET, HTTP, OPC-UA, S7comm	Process control S3
HMI S3	Siemens MTP700 Unified Comfort	172.21.3.10	30:13:89:2c:e9:c5	PROFINET	Operator panel
Camera	SensoPart	172.21.3.50	00:19:6F:0D:A3:72	HTTP	Monitoring ball distribution on tray

Station 4 — Magazine (172.21.4.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S4	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 4 distribution
PLC S4	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.4.1	30:b8:51:33:7e:24	PROFINET, HTTP, OPC-UA, S7comm	Process control S4

Asset	Model / Firmware	IP	MAC	Protocols	Function
HMI S4	Siemens MTP700 Unified Comfort	172.21.4.10	30:13:89:35:D9:EF	PROFINET	Operator panel
CPX Terminal	Festo CPX (197330)	TODO	TODO	TODO	Aggregate Festo Controllers monitoring data

Station 5 — Muscle Press (172.21.5.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
Switch S5	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 5 distribution
PLC S5	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.5.1	30:b8:51:33:7e:62	PROFINET, HTTP, OPC-UA, S7comm	Process control S5
HMI S5	Siemens MTP700 Unified Comfort	172.21.5.10	30:13:89:36:6A:EE	PROFINET	Operator panel

Station 6 — Oven (172.21.6.x)

Asset	Model / Firmware	IP	MAC	Protocols	Function
HMI S6	Siemens MTP700 Unified Comfort	172.21.6.10	30:13:89:35:d9:c7	PROFINET	Operator panel
Switch S6	Siemens SCALANCE XB008	unmanaged	unmanaged	Ethernet	Station 6 distribution
PLC S6	Siemens CPU 1512SP F-1 PN / V3.0.3	172.21.6.1	30:B8:51:32:D4:5F	PROFINET, HTTP, OPC-UA, S7comm	Process control S6
FESTO Controller - TODO					
Power Monitor S6	TODO	172.21.6.61	10:DF:FC:17:DC:6C	TODO	Power consumption monitoring

3.2 Network Diagram

Through physical inspection of the Festo plant, nmap host discovery, and Wireshark traffic captures, we mapped the current network architecture. The result is shown in the diagram below.

For better visibility, this diagram is attached separately to the report.

img/festo_plant_network_architecture_diagram.pdf

Figure 1: AS-IS Network Diagram

3.3 Communication Mapping

Source	Destination	Protocol	Port	Direction	Purpose
MES	PLC	OPC-UA	TCP 4840	MES(OPC-UA Client) to PLC(OPC-UA Server)	Read/write process data
HMI / PLC	MES	NTP	UDP 123	Clients(HMI/PLC) to MES(NTP Server)	Time sync (MES is NTP server)
Internet	MES	HTTPS	TCP 443	Internet to MES	Webshop orders
Cobot-ML PC	Camera	HTTP	TCP 80	Cobot-ML to Camera	Fetch inspection image from Camera server

Source	Destination	Protocol	Port	Direction	Purpose
Cobot-ML PC	PLC	OPC-UA	TCP 4840	Cobot-ML to PLC	Process data - based on image processing
PLC	IO Device	PROFINET	L2 / 34964	PLC to IO	Cyclic I/O exchange
Festo Controller	CPX-IOT (CVX)	MQTT	TCP 1883	Controller to CVX	Publish aggregated data
RFID Reader	PLC	PROFINET	L2 / 34964	Reader to PLC	RFID identification
PLC	Robot Arm	PROFINET	L2 / 34964	PLC to Robot	Motion commands / status
HMI	PLC	S7comm+	TCP 102	HMI to PLC	Read/write tags for panel
MES PC	PLC	S7comm-plus	TCP 102	MES to PLC	PLC programming
MES PC	HMI	S7comm-plus	TCP 102	MES to HMI	HMI programming/config
Power Monitor	Festo Cntroller	Modbus	TCP 502	Monitor to Controller	Power consumption data

4 AS-IS Architecture Security Analysis

4.1 Security Weaknesses

The overall posture is assessed as **CRITICAL**. The network presents no meaningful barrier between IT systems, engineering workstations, visitor devices, and live control equipment. A single compromised host has unrestricted access to all PLCs and HMIs. Findings are rated by exploitability and impact on availability, safety, and integrity. TODO: rewrite this paragraph - its very AI like.

Table 10: Security weaknesses summary

ID	Severity	Finding
F-01	CRITICAL	Fully flat /18 network — no zone or conduit separation
F-02	CRITICAL	PLCs directly reachable from all hosts — no access control
F-03	CRITICAL	MES PC has unrestricted protocol access to all OT devices
F-04	CRITICAL	Unregistered device actively programming PLCs via S7comm
F-05	HIGH	PLC web servers expose HTTP (plaintext) on the OT subnet
F-06	HIGH	OPC-UA servers accessible network-wide with no observed auth
F-07	HIGH	TP-Link AP on OT subnet — potential wireless attack surface
F-08	HIGH	Visitor/unvetted laptop (Kyan_laptop) on live OT network
F-09	HIGH	gebruik-tt8ke80 runs VMware with unknown VM roles on OT subnet
F-10	MEDIUM	CPX-IOT cloud gateway: function and traffic unconfirmed
F-11	MEDIUM	PROFINET carries no authentication — DCP allows rename/reconfigure
F-12	MEDIUM	Power monitor and CPX controller protocols unconfirmed
F-13	MEDIUM	Robot arm firmware version unverified
F-14	LOW	NTP provided only by MES PC — single point of failure
F-15	LOW	Undocumented devices not cross-referenced to switch ports

4.2 Security Weaknesses Findings

F-01 — Fully flat /18 network (IEC 62443-1-1; 3-3 SR 5.1/5.2; ISO 27001 A.8.22; NIS2 Art. 21)

Observation All 21+ live hosts share 172.21.0.0/18 with no VLAN, routed boundary, or firewall between device classes. PLCs, HMIs, MES, engineering PCs, visitor laptops, and infrastructure share one broadcast domain.

Impact Any compromised host has Layer 3 reachability to every PLC, HMI, and sensor. Lateral movement from an infected laptop to all six PLCs requires no further exploitation.

F-02 — Unrestricted PLC access (IEC 62443-3-3 SR 1.1/1.2/5.1)

Observation All S7-1500 PLCs expose HTTP/80, OPC-UA/4840, and S7comm/102 to the whole subnet, with no authentication observed at the network layer.

Impact Any host can connect to any PLC's S7comm port, read/write process data, up/download program blocks, or force a CPU STOP without credentials. All six stations are simultaneously vulnerable.

F-03 — No MES/OT separation (IEC 62443-2-1; 3-3 SR 5.2; ISO 27001 A.8.22)

Observation festo-mes-pc communicates directly with PLC S2 via HTTP (alarm polling), OPC-UA (process data), and NTP — unmediated, with no DMZ or proxy.

Impact Compromise of the Windows MES PC gives an attacker a trusted, persistent connection to PLC S2’s control interface; a malformed PLC response could also exploit the MES software.

F-04 — Unregistered device programming PLCs (IEC 62443-2-1; ISO 27001 A.8.1/A.8.19; Zero Trust)

Observation 172.21.0.156 maintained a persistent, high-volume S7comm session to PLC S2 across all captures and appears in no inventory; behaviour is consistent with TIA Portal in active programming mode.

Impact An unidentified device with S7comm write access to a live PLC is a rogue-programmer scenario: it can alter logic, inject faults, or cause unsafe states on Station 2 with no audit trail.

F-05 — PLC HTTP web servers in plaintext (IEC 62443-3-3 SR 1.3; Defense-in-Depth)

Observation PLC S2 serves HTTP/80; the MES issues unauthenticated GET requests to the alarm table about every 3 s. No TLS/HTTPS observed; the same web server exists on all PLCs.

Impact Alarm and diagnostic data travels in plaintext and can be intercepted or spoofed by any subnet host, which can also reach the diagnostic web interface without authentication.

F-06 — OPC-UA accessible network-wide (IEC 62443-3-3 SR 1.1; Least Privilege; Zero Trust)

Observation OPC-UA/4840 on PLC S2 receives connections from the MES PC and PC Cobot-ML. No certificate-based authentication or SecurityPolicy enforcement was verifiable; the server is likely in ‘None’ security mode (S7-1500 default).

Impact Any host on the /18 can connect and read/write process variables; ‘None’ mode gives no protection against eavesdropping, tampering, or replay.

F-07 — TP-Link access point on OT subnet (NIS2 Art. 21; IEC 62443-2-1; Defense-in-Depth)

Observation 172.21.0.200 was identified via UPnP SSDP as a TP-Link device running MiniUPnPd, broadcasting on UDP/20002.

Impact A wireless interface bridged to the OT subnet removes the physical perimeter; consumer firmware has a poor patch record, and MiniUPnPd is an internet-facing port-forwarding daemon that may expose OT services.

F-08 — Visitor/unvetted laptop on OT network (NIS2 Art. 21(2)(h); IEC 62443-2-1; Zero Trust)

Observation Kyan_laptop (172.21.0.179) was identified by DCP as SIMATIC-PC family (PROFINET drivers installed) and admitted to the OT subnet without restriction.

Impact A personal/student laptop is more likely to carry malware or be used on untrusted networks; once on the OT subnet it has the same PLC access as any device.

F-09 — VMware host with unknown VM roles (ISO 27001 A.8.1; IEC 62443-2-1; Defense-in-Depth)

<i>Observation</i>	gebruik-tt8ke80 presents a physical NIC and a VMware vNIC at the same IP; hosted VM roles and OS are unknown, and bridged VMs inherit OT subnet membership.
<i>Impact</i>	An internet-connected or unpatched VM provides a path from an untrusted environment to OT; hypervisor flaws can enable VM escape to a host with physical-layer OT access.

Medium / Low findings.

- **F-10:** Determine CPX-IOT internet connectivity; if present, place behind a dedicated firewall with strict egress and audit stored cloud credentials.
- **F-11:** Restrict PROFINET (L2, EtherType 0x8892) to known switch ports via VLAN/port security; disable DCP Set on production devices where supported.
- **F-12:** Characterise power-monitor and CPX-controller protocols (Modbus/502, IO-Link, REST); until confirmed, restrict to their station subnets.
- **F-13:** Confirm UR firmware via Polyscope and update; restrict UR ports 29999 and 30001–30004 to authorised hosts.
- **F-14:** Add a secondary NTP source and authenticate NTP (NTS or keys).
- **F-15:** Cross-reference MACs with switch ARP tables and physically trace cables; remove devices that cannot be identified.

4.3 Standards Compliance Status

Table 11: AS-IS standards compliance summary

Standard / Requirement	Requirement summary	Current status	Findings
IEC 62443-1-1 Zone & Conduit	Define zones; control conduits	NOT MET — single flat zone	F-01, F-02, F-03
IEC 62443-2-1 CSMS	Asset inventory, risk, access, change control	PARTIAL — incomplete inventory	F-04, F-09, F-15
IEC 62443-3-3 SR 5.1/5.2	Segmentation; zone boundary protection	NOT MET	F-01, F-02, F-03
IEC 62443-3-3 SR 1.1/1.2	User/device authentication	NOT MET — no auth on S7comm, HTTP, PROFINET	F-02, F-05, F-06, F-11
ISO/IEC 27001 A.8.1	Complete, maintained asset register	PARTIAL — 6+ devices absent	F-04, F-09, F-15
ISO/IEC 27001 A.8.22	Segregate services and users	NOT MET	F-01
NIS2 Art. 21	Segmentation, access control, asset mgmt	NOT MET	F-01–F-09
NIS2 Art. 21(2)(e)	Supply-chain risk management	NOT MET — unverified firmware	F-10, F-13
Defense-in-Depth	Multiple independent layers	NOT MET — single perimeter	F-01–F-04
Least Privilege	Minimum necessary access	NOT MET — unrestricted subnet access	F-02, F-03, F-06

Table 11: AS-IS standards compliance summary

Standard / Requirement	Requirement summary	Current status	Findings
Zero Trust	No implicit trust from location	NOT MET — trust by /18 membership	F-02, F-04, F-08

5 Threat & Risk Analysis

The analysis follows IEC 62443 principles and a simplified STRIDE model adapted for ICS. Industrial systems are sensitive because compromise can directly affect physical processes, safety, and production continuity, not just data.

5.1 Attacker Profiles

- **External attacker:** motivated by financial gain, disruption, or opportunistic exploitation; relies on phishing, misconfigured remote access, or known vulnerabilities.
- **Insider:** a user with legitimate access (operator, engineer, contractor); can bypass perimeter controls and poses the highest risk for silent tampering.
- **Student / opportunistic actor:** low sophistication but high local/physical access; responsible for accidental misconfiguration or simple exploitation of weak segmentation.

5.2 Threat Scenarios

- **PLC manipulation:** modifying control logic or setpoints, causing unsafe actuator behaviour or bypassed interlocks, usually via a compromised engineering workstation or insider access.
- **Denial of Service:** flooding network segments or exploiting protocol weaknesses to disrupt PLC/SCADA/HMI communication.
- **Unauthorized device access:** a rogue device introduced physically or via misconfiguration scans, impersonates trusted nodes, or interacts with PLC services.
- **Malware via Engineering PC:** a compromised engineering workstation pivots into PLC networks, extracts logic, or deploys malicious changes — one of the most critical ICS vectors.
- **Data manipulation via MES/Webshop:** altering production orders, parameters, or scheduling, leading to incorrect batches and downstream disruption.

5.3 Threat Table

Table 12: ICS threat analysis matrix (IEC 62443-based)

Asset	Threat	Attacker	STRIDE	Impact	Example
Engineering PC	Malware infection	External / Student	Info. disclosure, Tampering	Critical	Phishing leads to PLC compromise
Engineering PC	Unauthorized access	Insider	Elevation of privilege	Critical	Engineer account reused/misused
PLCs	Logic manipulation	External / Insider	Tampering, EoP	High	Modified logic alters actuators
PLCs	Command injection	Student / External	Spoofing	High	Fake control commands

Table 12: ICS threat analysis matrix (IEC 62443-based)

Asset	Threat	Attacker	STRIDE	Impact	Example
SCADA/HMI	Session hijacking	External	Spoofing	High	Operator session impersonated
Network segments	Traffic flooding	External	Denial of service	High	Broadcast storm disrupts PLCs
PLC network	Config exfiltration	External	Info. disclosure	High	PLC logic downloaded
MES system	Production manipulation	External / Insider	Tampering	High	Batch parameters altered
SCADA/HMI	Denial of service	External	Denial of service	Med-High	Operator loses visibility
Webshop/API	Data modification	External	Tampering, Info. disclosure	Med-High	Order data changed
Network switches	Rogue device	Student / Insider	Spoofing	Medium	Unauthorized laptop joins VLAN

5.4 Risk Matrix

Likelihood and impact are scored 1–4; risk score is their product.

Table 13: ICS threat risk assessment

Threat	Likelihood	Impact (safety / production / education)	Score	Priority
Engineering PC malware infection	High (3)	Critical (4): full control-layer compromise, persistent access	12	Critical
PLC logic manipulation	Medium (2)	Critical (4): unsafe actuators, shutdown, learning disruption	8	High
Unauthorized engineering access (insider)	Medium (2)	Critical (4): silent logic changes, safety bypass	8	High
SCADA/HMI denial of service	Medium (2)	High (3): loss of visibility, interruption	6	Medium
Network flooding / traffic storm	Medium (2)	High (3): loss of PLC comms, downtime	6	Medium
MES production manipulation	Medium (2)	High (3): incorrect runs, financial/operational impact	6	Medium
PLC config/data exfiltration	Medium (2)	High (3): IP loss, enables future attacks	6	Medium
Rogue device in network	Medium (2)	Medium (2): recon, lateral movement	4	Medium
Webshop/API data manipulation	Medium (2)	Medium (2): incorrect orders, indirect issues	4	Medium
PLC command spoofing	Low (1)	High (3): incorrect actions, physical instability	3	Low
Session hijacking (SCADA)	Low (1)	High (3): stealth manipulation, loss of trust	3	Low

6 Security Requirements

6.1 SR1: Network Segmentation

<i>SR-01</i>	Network Segmentation
<i>SR-01.1</i>	The network shall be divided into the following security zones: - OT Field Zone (PLCs, HMIs) - OT Cell Zone (MQTT Device, Cobot / ML vision PC, Engineering Workstation) - Industrial DMZ (OPC UA Proxy, MQTT Broker, Backup Server, Historian) - IT Zone (MES Server, COBOL Vision System)
<i>SR-01.2</i>	Each zone shall be implemented as a separate subnet/VLAN. Communication between zones shall only be permitted through firewall-controlled conduits.
<i>SR-01.3</i>	Direct communication from the IT Zone to the OT Field Zone shall be prohibited.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 5.1 – Restricted Data Flow - IEC 62443-1-1 – Zone and Conduit Model - NIS2 Article 21(2)(d)

6.2 SR2: Firewall with Protocol Inspection

<i>SR-02</i>	Firewall with protocol inspection
<i>SR-02.1</i>	The OT zones and IT zone shall be separated with the industrial firewall(s).
<i>SR-02.2</i>	Firewall rules shall enforce default-deny policy on all inter-zone traffic, with only explicitly whitelisted flows permitted: - OPC UA (TCP port 4840) from IMDZ OPC UA proxy to PLC's and Festo Controllers - MQTT (TCP port 8883 TLC) from MQTT device to MQTT broker in IDMZ
<i>Standards Reference</i>	- IEC 62443-3-3 SR 5.2 - IEC 62443-2-1 security management

6.3 SR3: OPC-UA Hardening

<i>SR-03</i>	OPC UA Hardening
<i>SR-03.1</i>	All OPC UA servers shall operate in Security Mode: Sign&Encrypt with SecurityPolicy:Basic256Sha256.
<i>SR-03.2</i>	Each client (MES, COBOL) must authenticate with an application certificate. Anonymous and username/password authentication sessions shall be disabled.
<i>SR-03.3</i>	OPC/UA servers shall not be reachable from the nodes inside IT zone directly, all access routes shall be set through a dedicated OPC UA proxy in IDMZ
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1, SR 1.3, SR 3.1; OPC UA Part 2 (Security Model)

6.4 SR4: MQTT Hardening

<i>SR-04</i>	MQTT Hardening
<i>SR-04.1</i>	The MQTT broker shall be hosted on a dedicated server inside IDMZ. All MQTT connections shall use TLS 1.2 or higher.
<i>SR-04.2</i>	Each MQTT publisher (MQTT CXV device) shall authenticate with a client certificate.
<i>SR-04.3</i>	Topic level ACLs must restrict publishers only to its own publish topics.
<i>SR-04.4</i>	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)

6.5 SR5: MQTT Hardening

<i>SR-05</i>	HTTP/Web Service Hardening
<i>SR-04.1</i>	All HTTP services on PLC's HMI's, Festo Controllers, and cameras shall be disabled unless strictly required for an operational functionality.
<i>SR-04.2</i>	If the Web Interface is required, it must be migrated to HTTPS (TLS 1.2+) with a device certificate, and access restricted by firewall to only specific source IP's of pooling systems.
<i>SR-04.3</i>	Topic level ACLs must restrict publishers only to its own publish topics.
<i>SR-04.4</i>	Nodes in IT zone shall only subscribe (not publish) to the OT topics.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)

6.6 SR6: Authentication and Least Privilege

<i>SR-06</i>	Authentication and Least Privilege
<i>SR-06.1</i>	All interactive access (PLC programming, HMI configuration, robot controller configuration) to the OT devices shall require individual user authentication.
<i>SR-06.2</i>	Role separation shall be enforced: - Operator (monitor only) - Engineer (upload programs, change parameters) - Administrator (device configuration, user management)
<i>SR-06.3</i>	PLC Programming access (TIA Portal) shall be only possible from designated Engineering Workstation.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 1.1–1.3; - IEC 62443-2-1 §4.3.3; - ISO/IEC 27001 A.9

6.7 SR7: Secure Engineering Access

<i>SR-07</i>	Secure Engineering Access
<i>SR-07.1</i>	A dedicated Engineering Workstation shall be physically or logically isolated from the IT Zone.
<i>SR-07.2</i>	The Engineering Workstation shall connect to PLC's only through industrial firewall via controlled conduit, with firewall rules permitting only TIA Portal protocols to the PLC's IP's.

6.8 SR8: Logging and Monitoring

<i>SR-08</i>	Logging and Monitoring
<i>SR-08.1</i>	All network devices (managed switches, routers, industrial firewalls, PLC's with switch modules) shall send logs to a centralized Syslog collector.
<i>SR-08.2</i>	The industrial firewalls shall log all denied traffic.
<i>SR-08.3</i>	OPC UA server shall log all sessions establishment and authentication failures.
<i>SR-08.4</i>	The MQTT broker shall log all connect/disconnect events and authentication failures.
<i>Standards Reference</i>	- IEC 62443-3-3 SR 6.1, SR 6.2; - NIS2 Article 21(2)(f); - ISO/IEC 27001 A.12.4

6.9 SR9: NTP/Time Synchronisation

<i>SR-09</i>	NTP/Time synchronization
<i>SR-09.1</i>	A single NTP server must be designated. All OT devices shall synchronize using this server.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Article 21(2)(c)

6.10 SR10: NTP/Time Synchronisation

<i>SR-10</i>	NTP/Time synchronization
<i>SR-10.1</i>	All PLC programs, HMI and Controllers configurations must be backed up after every change to and dedicated backup storage.
<i>SR-10.2</i>	Backup must be stored offline.
<i>SR-10.3</i>	Recovery procedure shall be documented and tested at least once per half a year.
<i>SR-10.4</i>	MES database shall be backed up once a day.
<i>Standards Reference</i>	- IEC 62443-2-1 §4.3.4; - ISO/IEC 27001 A.12.3; - NIS2 Article 21(2)(c)

7 TO-BE Architecture

7.1 Logical Network Redesign



Figure 2: Zone & Conduit Diagram

The current flat /18 network is replaced with a layered zone architecture based on the IEC 62443 zone and conduit model. Each zone groups devices with similar operational functions. All inter-zone traffic passes through a firewall and is restricted to explicitly whitelisted traffic paths.

7.1.1 Logic Zones

IT Zone

The IT Zone contains nodes handling business logic and order management. It have no direct routed path to any OT device - all IT to OT traffic goes through the IDMZ.

IDMZ

The IDMZ acts as a buffer between IT and OT devices. No connection is allowed to pass from the IT to OT and vice versa. Every traffic exchange terminates inside IDMZ, and its re-initiated to the other side. This solution implements IEC 62443-3-3 SR 5.1 principle.

OT Cell Zone

The OT Cell Zone Contains devices supporting production, but not being part of the physical production process. The Engineering Workstation is placed in this logical zone, however, in physical implementation, this node will be further isolated into separate VLAN.

OT Production Zone

The OT Production Zone contains devices being part of the direct physical production process. Only inbound traffic allowed in this zone are reads and writes from the proxy services, and S7comm+ from the engineering workstation.

7.1.2 New Nodes

OPC UA proxy

In the AS-IS architecture, MES can directly connect to the PLC's OPC UA servers over the flat network. OPC UA proxy node aggregates all PLC's OPC UA servers traffic into single endpoint inside IDMZ. The MES connects only to proxy, that is also responsible for enforcing rules on what nodes are readable and writable from the MES. Furthermore, it logs all sessions. This solution satisfies IEC 62443-3-3 SR 3.2.

Nginx

In AS-IS architecture, MES can directly access unencrypted HTTP services from the OT nodes. As stated in security requirements, all not strictly required HTTP servers of OT devices will be disabled. However, for required HTTP traffic (e.g PLC's alarm table <- MES) the Nginx node is introduced in IDMZ. MES connects to the Nginx over HTTPS TLS 1.2, terminates the connection, access the requested HTTP node server and forwards it to the MES. Nginx enforces authentication, logging all requests and block requests for services that should not be reached from IT zone.

Dedicated MQTT broker

In the AS-IS architecture MQTT CVX device publish messages over a flat network to the MES. MQTT broker node placed in IDMZ, aggregates MQTT traffic from the CVX device using TLS 1.2 encryption, and it restrict inbound traffic to publish messages only. MES is subscribes to the MQTT broker, preventing direct communication between OT node and IT node. This solution satisfies IEC 62443-3-3 SR 1.1 and SR 3.1.

Engineering Workstation

In the AS-IS architecture, TIA Portal is run on the same PC as MES service - part of IT and reachable over flat network. A dedicated Engineering Workstation is placed in the OT Cell Zone (physically on separate VLAN). This workstation purpose is to program and configure PLC's and HMI's with separation from IT nodes. Traffic is restricted only to TCP 102 on PLC's and HMI's. This enforces least-privilege and IEC 62443-2-1 §4.3.3.

Syslog

In the AS-IS architecture, there is no centralized logging system implemented. Syslog node collects all logs from the firewalls, managed switches, OPC UA and HTTP proxy, and MQTT broker. This provides post-attack analysis and satisfies IEC 62443-3-3 SR 6.1 and NIS2 Article 21(2)(f). **Backup** In AS-IS architecture, there is no documented backup procedure. The backup node receives configuration backups from the Engineering Workstation after every change and daily database backups from the MES. It is placed on separate VLAN inside IT zone, separated from inbound traffic from OT. Satisfies IEC 62443-2-1 §4.3.4 and ISO/IEC 27001 A.12.3.

7.1.3 Firewalls

This section only describes briefly the high-level purpose of the firewall nodes. Further specification on permitted conduits is described in 7.2.2. TODO chapter reference

Edge Firewall

Terminates all VPN tunnels from remote engineers and vendor support, enforces MFA before any traffic enters the IT zone, and blocks all unsolicited inbound connections from the internet. Default-deny on all inbound. Satisfies IEC 62443-2-1 §4.3.3.6 and NIS2 Article 21(2)(i).

IT - DMZ Firewall

Controls all traffic between the IT zone and the IDMZ.

DMZ - OT Cell Firewall

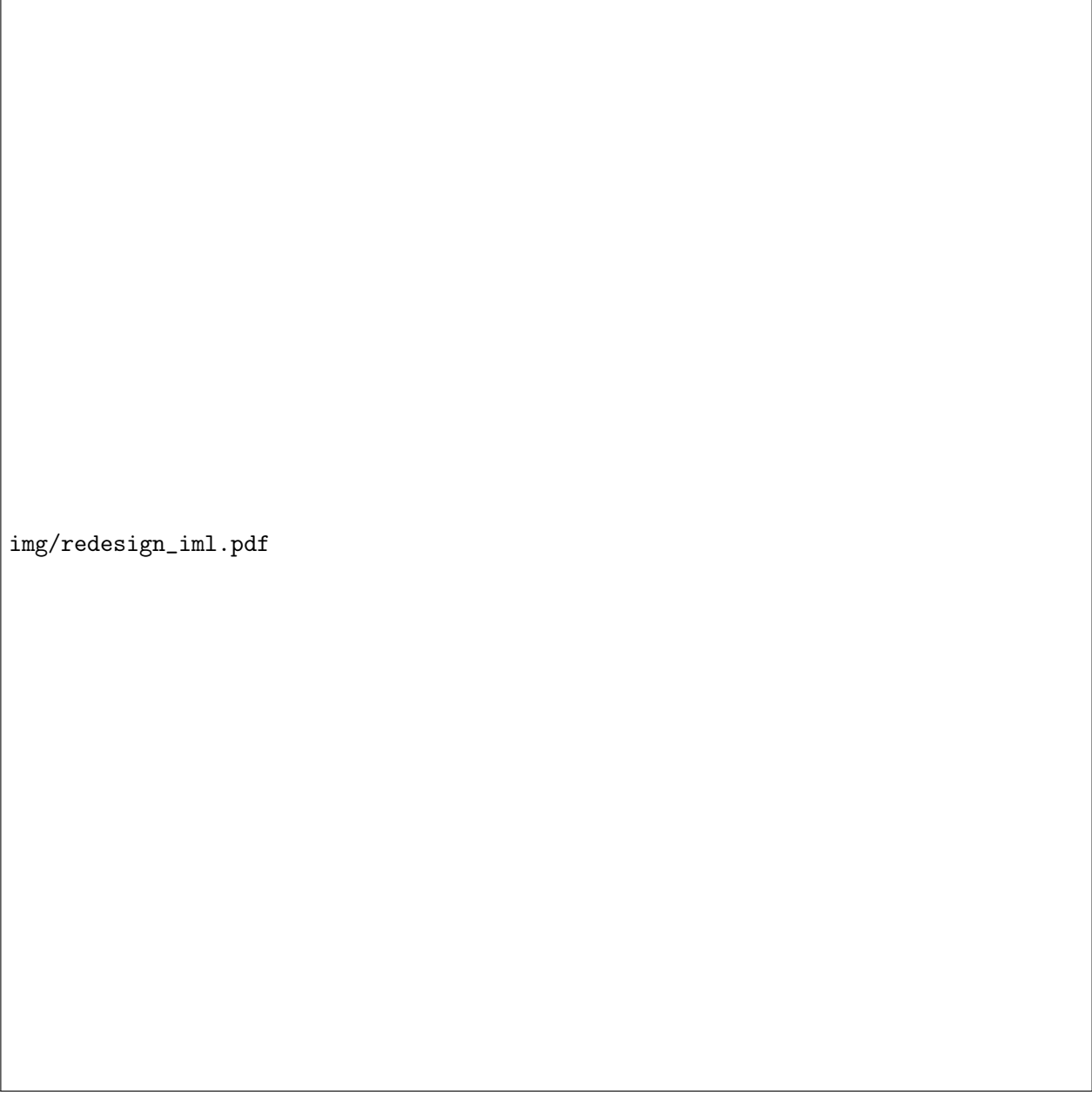
Controls traffic between the IDMZ and the OT cell zone.

OT Cell - OT Production Firewall

Controls traffic between the OT cell zone and the six station VLANs. OPC UA proxy connections arrive from the IDMZ side, not the cell zone side, so they do not pass this firewall. Profinet never crosses this boundary — it remains Layer 2 within each station. All other traffic denied. Satisfies IEC 62443-3-3 SR 5.1 and the least privilege principle.

7.2 Network Implementation

The Network Implementation diagram is appended to the report for better visibility.



img/redesign_uml.pdf

Figure 3: Network Implementation

7.2.1 VLAN Segmentation & Restricted Routing

The redesigned factory network is implemented using VLAN-based segmentation on managed industrial switches. Each security zone is assigned a dedicated VLAN and IP subnet. Inter-VLAN communication is not performed by the switch itself but is routed through a central industrial firewall. The firewall has one tagged VLAN port for each VLAN - which is a default gateway for each node within that VLAN. The firewall enforces security policies between zones. A VLAN trunk connection between the firewall and the managed switch transports traffic for all security zones while preserving logical separation through IEEE 802.1Q VLAN tagging.

Because the switch never bridges VLANs, the only path between any two zones is through the firewall. The firewall applies a default-deny policy: traffic between VLANs is dropped unless a rule explicitly permits it. Traffic within a VLAN (for example PLC-to-HMI Profinet inside one station) is switched locally and never reaches the firewall. Profinet RT traffic is Layer 2 only and is confined to its station VLAN; it is never routed across the firewall. This realises the four logical firewall boundaries (Edge, IT-IDMZ, IDMZ-OT Cell, OT Cell-OT Production) on a single physical firewall,

where each boundary corresponds to a rule set between the relevant VLAN interfaces. It satisfies IEC 62443-3-3 SR 5.1 (Restricted Data Flow) and SR 5.2 (Zone Boundary Protection).

VLAN	Zone	Nodes
10	IT	MES PC, Data Storage PC
20	IDMZ	Proxy PC
30	OT Cell	COBOL PC, MQTT CVX
40	OT Cell - Engineering	Engineering Workstation
101	OT Prod - Station 1	PLC1, HMI1, UR3e Robot Arm Controller, TURCK position sensor
102	OT Prod - Station 2	PLC2, HMI2, I/O device, Festo Controller
103	OT Prod - Station 3	PLC3, HMI3, SensoPart Camera
104	OT Prod - Station 4	PLC4, HMI4
105	OT Prod - Station 5	PLC5, HMI5
106	OT Prod - Station 6	PLC6, HMI6, Festo controller

8 Hardware & Configuration Proposal

8.1 Protocol Hardening

The redesign (Chapter 7 TODO) controls where each protocol may flow. This chapter defines how each protocol is secured on the device and conduit level.

8.1.1 Profinet

Profinet has no authentication or encryption features, so it cannot be hardened at the protocol level. Instead it is secured by isolation.

- Layer 2 only - Profinet stays inside each OT Production station (VLAN 101 - 106). It is never routed, and never crosses through firewall. Even if routing would be executed (through the attack) router would drop the communication.
- No inter-station Profinet communication - Each PLC talks Profinet (with I/O, HMI) only within own VLAN.
- DCP Set disabled - disable DCP Set through TIA Portal for devices that support this feature. This prevents rename/reconfigure attacks through DCP.

8.1.2 OPC UA

OPC UA is the only routed OT data protocol. Hardening is specified in SR-03. (*see Security Requirements ??*)

- Security mode Sign&Encrypt - Security policy Basic256Sha256. Mode 'none' is disabled on all PLC and Festo Controllers servers.
- Certificate authentication - Clients (OPC UA proxy, Cobot/MLvisionPC) authenticate with application certificates. Anonymous and username/password sessions are disabled.

- Scoped access - The Cobot/MLvisionPC can reach only PLC2 on Station 2, and no other PLC's.

8.1.3 MQTT

MQTT is used by the Festo CXV device for telemetry. It's hardening is specified in SR-04 (*see Security Requirements ??*)

- MQTT broker in IDMZ - The MQTT CXV device publishes only to a dedicated MQTT broker placed in IDMZ. IT nodes can only subscribe to the broker. No direct OT-IT MQTT path exists.
- TLS 1.2+ - TLS encryption enforced on all MQTT connections.
- Client certificates - MQTT CXV device must authenticate with certificate for publish connection to the broker. No anonymous connections allowed.
- Topic ACL's - The MQTT CXV device may publish only to it's own topics. IT nodes (MES) cannot publish to the OT topics.

8.1.4 HTTP/Web Interfaces

Some OT devices need to expose plaintext HTTP web interfaces. Hardening is specified in SR-05 (*see Security Requirements ??*)

- Disabled by default - All HTTP servers are disabled unless strictly needed for operational functionality.
- Reverse proxy - Where web access is needed (e.g. MES reading the PLC alarm table), the MES connects to the Nginx reverse proxy in the IDMZ over HTTPS/TLS 1.2+. Nginx terminates the connection, fetches the OT-side resource, and returns it. Plaintext HTTP stays inside the OT zone.
- Access restriction - Nginx authenticate requests, logs them and blocks any OT server that should not be reached from IT zone. Firewall rules restrict web access to the Nginx TCP/IP port only.

8.1.5 S7comm+ Engineering Access

S7comm+ connection is used only for programming PLC's and HMI's. Hardening is specified in Security Requirements ?? and ??

- Single source - S7comm+/TCP102 to any PLC or HMI is allowed only from the dedicated Engineering Workstation in VLAN40.
- Conduit control - Engineering Workstation S7comm+ connection initialization passes through the firewall, enforcing restriction of Engineering Station to PLC's and HMI's only.
- User Authentication - PLC's and HMI's access requires individual login/password authentication with role separation (implemented in TIA portal).

8.2 Hardware Proposal

This chapter lists the hardware required to implement the redesigned architecture (Chapter 7).

8.2.1 Industrial Firewall

Model	Fortinet FortiGate Rugged 70G
Function	Central Layer 3 firewall and inter-VLAN router. All traffic between VLANs passes through it - under default-deny policies. Can perform stateful filtering and packet inspection of industrial protocols (S7comm+, OPC UA, MQTT, HTTP/S). Implements four logical firewalls (Edge, IT-IDMZ, IDMZ-OT Cell, OT Cell-OT Production) as separate rule sets between VLAN interfaces.
Placement	Network core. Has one tagged VLAN interface (.254 gateway) per VLAN. Has single 802.1Q trunk to the managed switch. No VLAN is bridged on the switch, so the firewall is the only inter-VLAN path.

8.2.2 Managed Switch

Model	Siemens SCALANCE XC-216
Function	VLAN-aware Layer 2 switching with IEEE 802.1Q tagging. Provides per-station access ports (untagged, one VLAN each) and the trunk uplink to the firewall.
Placement	Replace the existing unmanaged SCALANCE XB008 switches at each station. Interconnected by 802.1Q trunks; one trunk reaches the firewall.

8.2.3 Engineering Station

Model	Siemens SIMATIC IPC627E
Function	Dedicated managed station running TIA Portal for PLC and HMI programming/configuration. Only host permitted S7comm+ to PLCs/HMIs.
Placement	OT Cell zone, isolated in its own VLAN (40). Reaches OT Production only through the firewall on TCP 102.

8.2.4 IDMZ proxy server

Model	Industrial rack server or SIMATIC IPC. Hardened Linux.
Function	Hosts the IDMZ services — OPC UA proxy, Nginx reverse proxy, MQTT broker, NTP master, log forwarder, backup staging.
Placement	Placed inside IDMZ zone - on VLAN20.

8.2.5 Syslog & Backup Storage

Model	Standard server, Linux OS.
Function	Central Syslog collector for firewall, switches, proxies and broker; offline configuration backups (after every change) and daily MES database backups over SFTP.
Placement	IT zone, VLAN10

9 Standards Alignment

This section briefly describes each standard referenced in the report and lists the design and implementation measures applied against it.

9.1 IEC 62443

A series of standards for security of Industrial Automation and Control Systems (IACS). Part 1-1 defines the zone-and-conduit model; part 2-1 covers the cybersecurity management system (asset inventory, access management, change control, time and backup); part 3-3 defines system security requirements (SRs) for authentication, data flow restriction, and monitoring.

Measures applied:

- Zone & conduit model (1-1): four zones (IT, IDMZ, OT Cell, OT Production) with all inter-zone traffic through firewall conduits (SR-01, TO-BE §6).
- Restricted data flow / zone boundary protection (3-3 SR 5.1/5.2): VLAN segmentation routed through a single industrial firewall under default-deny; the IDMZ terminates and re-initiates all IT-OT exchanges.
- Authentication (3-3 SR 1.1–1.3): OPC UA Sign&Encrypt with certificates; MQTT TLS with client certificates; HTTPS web access; individual PLC/HMI logins with role separation.
- Logging (3-3 SR 6.1/6.2): central Syslog from firewalls, switches, proxies, and broker; firewalls log denied traffic.
- CSMS (2-1): dedicated Engineering Workstation and controlled change access (§4.3.3); single NTP source and backup/recovery (§4.3.4); Edge Firewall with MFA for remote access (§4.3.3.6).

9.2 ISO/IEC 27001

An information security management standard whose Annex A controls are applied here in an OT context: asset management (A.8.1), network segmentation (A.8.22), network security (A.8.20), access control (A.9), logging (A.12.4), and backup (A.12.3).

Measures applied:

- Asset management (A.8.1): structured inventory; requirement to identify and document undocumented devices (F-04, F-15).
- Segmentation and network security (A.8.22, A.8.20): VLAN/firewall separation between all zones (SR-01, SR-02).
- Access control (A.9): role-based access with individual accounts (SR-06).
- Logging (A.12.4): centralised Syslog (SR-08).
- Backup (A.12.3): scheduled, offline backups with tested recovery (SR-10).

9.3 NIS2 Directive

An EU directive on cybersecurity risk management for essential and important entities. Article 21 covers risk-management measures, including segmentation and access control (21(2)(d)), time/backup (21(2)(c)), monitoring (21(2)(f)), basic cyber hygiene (21(2)(h)), supply-chain security (21(2)(e)), and secure remote access (21(2)(i)).

Measures applied:

- Risk management / segmentation (Art. 21, 21(2)(d)): zoned network with controlled conduits (SR-01).
- Backup and time (21(2)(c)): single NTP source and backup/recovery (SR-09, SR-10).
- Monitoring (21(2)(f)): central logging (SR-08).
- Cyber hygiene (21(2)(h)): network admission control and MQTT/TLS hardening (F-08, SR-04).
- Secure remote access (21(2)(i)): Edge Firewall with VPN termination and MFA.
- Supply chain (21(2)(e)): firmware verification of multi-vendor devices (F-10, F-13).

9.4 Defense-in-Depth

The principle of multiple independent, layered controls so that no single failure exposes the whole system.

Measures applied: layered zones (IT, IDMZ, OT Cell, OT Production) with a firewall at each boundary; per-protocol hardening on top of segmentation; the IDMZ as an additional buffer that prevents direct IT-OT paths; logging and backup as fallback/recovery layers.

9.5 Least Privilege & Zero Trust

Least privilege grants each component only the access it needs; Zero Trust grants no implicit trust based on network location.

Measures applied: default-deny firewall with explicitly whitelisted protocol routes (§6.4); the Cobot/ML vision PC scoped to PLC2 only; S7comm+ permitted only from the Engineering Workstation in VLAN 40; OPC UA reachable only via the IDMZ proxy; trust based on authenticated identity and certificates rather than subnet membership.

10 Discussion and Limitations

TODO merge

10.1 Organizational & Procedural Measures

10.1.1 User Roles

Three roles, enforced on PLCs, HMIs, controllers, and the robot (SR-06.2). All access uses individual accounts — no shared logins.

Role	Permissions	Typical User
Operator	Monitor HMIs, access Web Interfaces. No configuration or program changes.	Student running a session
Engineer	Upload/modify PLC programs and parameters, configure HMIs. Login through Engineering Workstation only.	Lab technician / Teacher
Administrator	Device configuration, user and certificate management, firewall and switch configuration.	Lab administrator

10.1.2 Backup Strategy

Backup Strategy is specified in SR-10 (see TODO).

- PLC programs, HMI configurations, and controller configs are backed up after every change.
- The MES database is backed up daily.
- Backups go to dedicated backup storage (VLAN 10) and a copy is kept offline.
- Recovery procedures are documented and tested at least twice per year.

10.1.3 Incident Response

- Detect — Anomalies surface from the Syslog collector and firewall denied-traffic logs (SR-08). Operators report unexpected station behaviour immediately.
- Contain — Isolate the affected device or VLAN (disconnect or firewall block). Stop the station if process safety is in doubt.
- Preserve — Keep logs and alarms.
- Recover — Restore PLC/HMI config or MES data from the last known-good backup (SR-10.4).
- Document — Record what happened, the cause, and the fix.

10.2 Data Capture Limitations

The network traffic captures used for the AS-IS analysis and inventory in this report were taken while the FESTO Smart Factory was operated manually at the lab, rather than running its full automated production cycle. We were unable to get the plant running end-to-end during the sessions allocated for traffic capture, which means some communication flows are inferred from documentation and partial observation rather than confirmed in live traffic.

In particular, this affects:

- **Cyclic PROFINET I/O exchange** between the PLC and field devices — only short bursts were captured rather than a full production cycle, so timing characteristics (cycle time, jitter) could not be reliably established.
- **Robot arm motion sequences** — captured only for isolated test movements, not a complete pick-and-place cycle, so the full range of commands exchanged with the PLC may not be reflected in our Communications Mapping.

- **MES-triggered workflows** — webshop order processing and the resulting MES-to-PLC instructions could not be captured under realistic load, since we did not have a live order to trigger the flow during our session.

As a result, the inventory and AS-IS architecture in this report should be read as a best-effort reconstruction based on the captures we did obtain, supplemented by vendor documentation and protocol specifications where direct observation was not possible. A follow-up assessment with access to a fully operational production run would be needed to confirm completeness of the communications map and to rule out any device or flow not visible during our limited window.

10.3 General Reflection

Working with a physical lab environment introduced constraints that a purely desk-based security assessment would not face. Access to the FESTO plant was time-boxed and shared with other coursework groups, which limited how much we could experiment with capture conditions or repeat captures under different operating states. This is a realistic constraint in any OT environment, however — production systems are rarely available on demand for security assessment either, and our experience reflects a smaller-scale version of the access negotiation that real OT security assessments require.

The exercise also reinforced a recurring theme in OT security: the gap between an idealised Purdue-model architecture and what is actually deployed in practice. Several of the flows we did capture did not cleanly map to the zone boundaries we expected going in, which shaped both our threat modelling and several of the security requirements in Section ?? (notably the explicit firewall conduits in SR-01 and SR-02). We consider this a useful finding in its own right: it suggests that segmentation work on a system like this needs to start from observed traffic rather than assumed architecture.